

☒ Easy (10 Questions)

1. What is the goal of data extraction in web security testing?

- A) Encrypt user passwords
- B) Extract useful information from applications
- C) Format the database schema
- D) Modify application themes

☒ Answer: B

Explanation: Data extraction is about retrieving valuable data (e.g., usernames, emails, session tokens) from an application.

2. Which tool is commonly used to intercept and modify HTTP requests?

- A) FileZilla
- B) Visual Studio
- C) Burp Suite
- D) Postman

☒ Answer: C

Explanation: Burp Suite is widely used for capturing and altering HTTP traffic to discover vulnerabilities.

3. What is an example of sensitive data that attackers try to extract?

- A) Color schemes
- B) Usernames and passwords
- C) Image formats
- D) CMS themes

☒ Answer: B

Explanation: Sensitive data includes credentials, financial records, and personal data.

4. Which of the following helps automate data extraction?

- A) WordPress
- B) Python scripts
- C) PowerPoint
- D) FTP

☒ Answer: B

Explanation: Python is frequently used to automate interactions with vulnerable endpoints.

5. What is an example of an identifier useful in reconnaissance?

- A) Screen resolution
- B) Email address
- C) Font size
- D) Java version

☒ Answer: B

Explanation: Emails are useful for enumerating users and launching phishing attacks.

6. What is an indicator that sensitive data may be exposed?

- A) 404 error
- B) Commented-out credentials in source code

- C) CDN usage
- D) JavaScript animations

☒ **Answer: B**

Explanation: Exposed comments may contain hardcoded credentials or API keys.

7. What does SQL injection commonly aim to do?

- A) Change page background
- B) Bypass login pages and extract database data
- C) Redirect DNS
- D) Modify browser cache

☒ **Answer: B**

Explanation: SQL injection allows attackers to retrieve, alter, or delete backend database information.

8. What type of HTTP method is often used for data extraction via API?

- A) HEAD
- B) TRACE
- C) GET
- D) CONNECT

☒ **Answer: C**

Explanation: The GET method is used to retrieve data from a server.

9. What does "enumeration" refer to in penetration testing?

- A) Counting rows in a table
- B) Identifying and listing resources like usernames, directories
- C) Running performance tests
- D) Logging events

☒ **Answer: B**

Explanation: Enumeration involves listing entities like users, files, and services.

10. What kind of response would indicate a successful directory traversal?

- A) HTTP 403
- B) HTTP 404
- C) HTTP 500
- D) Access to system files (e.g., /etc/passwd)

☒ **Answer: D**

Explanation: Directory traversal allows access to unintended files.

☒ Medium (20 Questions)

11. What does "information disclosure" refer to in web applications?

- A) Sharing analytics
- B) Exposing internal data unintentionally
- C) Caching problems
- D) Color accessibility

☒ **Answer: B**

Explanation: It refers to leaks of internal or sensitive data due to weak security.

12. What is the main risk with verbose error messages?

- A) Slower response time
- B) Giving attackers clues about the system
- C) UI distortion
- D) Inaccurate user analytics

☒ **Answer: B**

Explanation: Detailed error messages can expose tech stacks or query structures.

13. How can a robot.txt file be abused?

- A) For DDoS
- B) It reveals paths the admin doesn't want indexed
- C) It's not related to security
- D) It hides CSS styles

☒ **Answer: B**

Explanation: Sensitive directories listed in robots.txt can help attackers.

14. Which tool is best for brute-forcing hidden files/directories?

- A) SQLMap
- B) Dirb / Dirbuster
- C) Netcat
- D) Telnet

☒ **Answer: B**

Explanation: Tools like Dirbuster brute-force common file paths.

15. What HTTP header could reveal internal software details?

- A) Content-Type
- B) Server
- C) Accept-Encoding
- D) X-Forwarded-For

☒ **Answer: B**

Explanation: The Server header may show Apache, Nginx, and versions.

16. What is "parameter tampering"?

- A) Disabling JavaScript
- B) Changing URL or form values to manipulate behavior
- C) Modifying CSS
- D) Rotating tokens

☒ **Answer: B**

Explanation: It's altering GET/POST parameters to bypass validation or escalate privileges.

17. What is "IDOR"?

- A) Identifier Over Response
- B) Insecure Direct Object Reference
- C) Information Disclosure Over Rewrites

D) Indirect Output Reader

☒ **Answer: B**

Explanation: It allows unauthorized access to resources by modifying object references.

18. What is a sign of blind SQL injection?

A) Table dumps

B) Time delays in responses

C) Password resets

D) 500 error

☒ **Answer: B**

Explanation: Blind SQLi doesn't return data, but attackers observe timing or boolean logic.

19. What is the purpose of Burp Suite's Intruder tool in exploitation?

A) Generate CAPTCHA

B) Automate custom payload attacks

C) Encrypt sessions

D) Schedule backups

☒ **Answer: B**

Explanation: Intruder is used to automate brute force, fuzzing, and enumeration.

20. What kind of data can be extracted from JavaScript files?

A) HTML comments

B) Internal APIs or logic

C) PHP errors

D) CSS themes

☒ **Answer: B**

Explanation: JavaScript often reveals hidden endpoints or logic paths.

21. Which file might reveal database connection strings if exposed?

A) .htaccess

B) .env

C) robots.txt

D) sitemap.xml

☒ **Answer: B**

Explanation: .env files often store environment variables like DB credentials.

22. What is fuzzing?

A) Obfuscating JavaScript

B) Sending varied unexpected inputs to find issues

C) Encoding logs

D) Creating session tokens

☒ **Answer: B**

Explanation: Fuzzing tests input handling robustness using many random inputs.

23. What does LFI allow an attacker to do?

A) List files alphabetically

B) Load local files on the server

- C) Format user input
- D) Inject SQL queries

☒ **Answer: B**

Explanation: Local File Inclusion (LFI) loads unintended files into execution context.

24. Which technique is commonly used to exploit LFI to achieve RCE?

- A) Reverse shell via /proc/self/environ
- B) Using CDN
- C) Editing stylesheets
- D) DNS spoofing

☒ **Answer: A**

Explanation: Attackers upload code, then include it via LFI to execute commands.

25. What is SSRF?

- A) Server-Side Random Filter
- B) Server-Side Request Forgery
- C) Secure Script Rendering Function
- D) Session State Resource Flush

☒ **Answer: B**

Explanation: SSRF tricks a server into making unintended requests.

26. Which response code may indicate a successful SSRF test?

- A) 200 OK with internal data
- B) 404 Not Found
- C) 301 Redirect
- D) 403 Forbidden

☒ **Answer: A**

Explanation: SSRF often returns internal service data via a 200 status.

27. What's an effective way to detect IDOR?

- A) Change numeric object IDs in URLs
- B) Use DNS enumeration
- C) Obfuscate JS
- D) Modify cookies

☒ **Answer: A**

Explanation: If unauthorized access is possible by changing an ID, it's IDOR.

28. In a login bypass attempt, changing isAdmin=false to true is an example of?

- A) Command injection
- B) Boolean parameter manipulation
- C) Race condition
- D) HTML injection

☒ **Answer: B**

Explanation: Modifying boolean parameters can lead to privilege escalation.

29. What is the purpose of reconnaissance in exploitation?

- A) Obfuscate traffic

- B) Identify exploitable services and endpoints
- C) Cache results
- D) Reduce entropy

☒ **Answer: B**

Explanation: Reconnaissance gathers data to aid in attacks.

30. What HTTP method is most often misused in IDOR vulnerabilities?

- A) POST
- B) PUT
- C) DELETE
- D) GET

☒ **Answer: D**

Explanation: GET requests often contain object IDs, vulnerable to tampering.

☒ **Hard (10 Questions)**

31. What is a key benefit of chaining SSRF with metadata APIs?

- A) Gain resource usage
- B) Extract IAM credentials from cloud providers
- C) Restart the server
- D) Remove headers

☒ **Answer: B**

Explanation: In AWS/GCP, SSRF can query metadata endpoints for credentials.

32. What vulnerability does the ../../../../etc/passwd pattern indicate?

- A) LFI
- B) SSRF
- C) SQLi
- D) RFI

☒ **Answer: A**

Explanation: This is a classic Local File Inclusion (LFI) payload.

33. What technique does an attacker use to evade input filters in LFI?

- A) Encoding payloads (e.g., URL-encoding)
- B) Changing the IP
- C) Brute force
- D) Changing HTTP methods

☒ **Answer: A**

Explanation: Encoding ../ as %2e%2e%2f helps bypass filters.

34. What is a key characteristic of time-based blind SQLi?

- A) Errors in response
- B) Long server response delays
- C) Session resets
- D) Browser crash

☒ **Answer: B**

Explanation: Attackers use SLEEP() or similar to test for SQLi via delay.

35. What is the risk in exposed .git directories?

- A) JavaScript minification
- B) Revealing entire source code history
- C) Slower loading
- D) Form injection

☒ **Answer: B**

Explanation: .git leaks can expose the source, credentials, and config.

36. How can an attacker gain RCE from a file upload flaw?

- A) Uploading a script and accessing it via browser
- B) Uploading large files
- C) Embedding SVG
- D) Modifying cache headers

☒ **Answer: A**

Explanation: RCE can be achieved by uploading PHP/ASP and executing via path.

37. How does WAF bypass help exploitation?

- A) Slows down response
- B) Triggers more logs
- C) Evades filters to allow payloads
- D) Breaks JS validation

☒ **Answer: C**

Explanation: Web Application Firewall (WAF) evasion allows payloads to pass through.

38. What is XXE exploitation used for?

- A) Injecting JavaScript
- B) Extracting files via XML parser
- C) Rewriting headers
- D) Creating JWTs

☒ **Answer: B**

Explanation: XML External Entity attacks target XML parsers to extract internal files or SSRF.

39. What advanced technique helps find broken access controls?

- A) Role manipulation via session IDs
- B) Modifying server firmware
- C) CAPTCHA solving
- D) DNS hijacking

☒ **Answer: A**

Explanation: Changing session tokens or roles can reveal flaws in access logic.

40. What is an “out-of-band” exploitation?

- A) One requiring no user input
- B) One that sends data back via separate channels (e.g., DNS or HTTP callbacks)
- C) Multi-step login

D) One using CSS

☒ **Answer: B**

Explanation: OOB techniques use separate communication methods for data exfiltration.